INSTITUCIÓN UNIVERSITARIA DIGITAL DE ANTIOQUIA

FACULTAD DE INGENIERÍA • TECNOLOGÍA EN DESARROLLO DE SOFTWARE
CURSO: CIBERSEGURIDAD

EVIDENCIA OFICIAL DE REGISTROS DE AUDITORÍA Y TRAZAS DE EJECUCIÓN
Demostración Técnica y Evaluación en Vivo — Unidad 2

Estudiante: Mariluz David Martínez | davidmaryluz6@gmail.com
Repositorio GitHub: davidmaryluz6-stack / laboratorio-ciberseguridad-mariluz-david-martinez
Servidor DMZ: https://laboratorio-ciberseguridad-mariluz-david.onrender.com
Fecha: Noviembre de 2026

Este anexo documental consolida las bitácoras reales de ejecución y eventos de auditoría perimetral obtenidos en el laboratorio. Se detalla el entorno de ejecución de cada registro, diferenciando el nodo desplegado en la nube pública (Render) de los módulos pedagógicos ejecutados de forma controlada en la red aislada de Docker local.

1. Registros de Auditoría en Render Cloud (Módulo 00 — Servidor DMZ)

Origen: Servicio Web en Render (https://laboratorio-ciberseguridad-mariluz-david.onrender.com)
Service ID: srv-dbnav2gu01pc73c86p0g | Entorno: Docker / Gunicorn en Producción.
Explicación: Registros emitidos por el middleware de auditoría hacia stdout al procesar solicitudes HTTP en vivo. Las marcas temporales y códigos HTTP corresponden a los eventos reales capturados en la nube:

```
AUDIT_LOG | timestamp_utc=2026-11-07T05:00:46Z | method=GET | path=/health | status_code=200
AUDIT_LOG | timestamp_utc=2026-11-07T05:05:48Z | method=GET | path=/health | status_code=200
AUDIT_LOG | timestamp_utc=2026-11-07T05:05:53Z | method=GET | path=/ | status_code=200
AUDIT_LOG | timestamp_utc=2026-11-07T05:07:10Z | method=GET | path=/ | status_code=200
AUDIT_LOG | timestamp_utc=2026-11-07T05:07:12Z | method=GET | path=/health | status_code=200
```

2. Registros de Ejecución en Docker Local Aislado (Módulos 01 al 07)

Origen: Contenedores en red privada Docker Compose ('lab-dmz-net' con directiva 'internal: true').
Explicación técnica: Salidas auténticas de consola generadas durante la ejecución de los contenedores de prueba contra el contenedor local 'servidor-dmz'. Ninguna de estas solicitudes fue dirigida a la nube de Render ni a redes públicas de Internet.

Módulo 01: Simulación de Tráfico Masivo (DoS Controlado)

Contexto técnico: Ráfaga paralela pedagógica de 30 solicitudes concurrentes con curl hacia http://servidor-dmz:8080. El servidor atendió todas las peticiones con HTTP 200 sin saturación.
Aclaración: Constituye una simulación de concurrencia y no una denegación de servicio real.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 01: Simulación de Tráfico Masivo (DoS Controlado)
================================================================
[INFO] Objetivo local asignado: http://servidor-dmz:8080
[SEGURIDAD OK] El objetivo pertenece a la red privada y controlada del laboratorio.
[SIMULACIÓN] Iniciando ráfaga controlada de 30 solicitudes HTTP concurrentes...
  -> Petición #11: HTTP 200 [Recibida por DMZ]
  -> Petición #6: HTTP 200 [Recibida por DMZ]
  -> Petición #9: HTTP 200 [Recibida por DMZ]
  -> Petición #4: HTTP 200 [Recibida por DMZ]
  -> Petición #25: HTTP 200 [Recibida por DMZ]
  -> Petición #3: HTTP 200 [Recibida por DMZ]
  -> Petición #23: HTTP 200 [Recibida por DMZ]
  -> Petición #18: HTTP 200 [Recibida por DMZ]
  -> Petición #26: HTTP 200 [Recibida por DMZ]
  -> Petición #21: HTTP 200 [Recibida por DMZ]
  -> Petición #22: HTTP 200 [Recibida por DMZ]
  -> Petición #27: HTTP 200 [Recibida por DMZ]
  -> Petición #1: HTTP 200 [Recibida por DMZ]
  -> Petición #14: HTTP 200 [Recibida por DMZ]
  -> Petición #16: HTTP 200 [Recibida por DMZ]
  -> Petición #15: HTTP 200 [Recibida por DMZ]
  -> Petición #12: HTTP 200 [Recibida por DMZ]
  -> Petición #24: HTTP 200 [Recibida por DMZ]
  -> Petición #17: HTTP 200 [Recibida por DMZ]
  -> Petición #8: HTTP 200 [Recibida por DMZ]
  -> Petición #29: HTTP 200 [Recibida por DMZ]
  -> Petición #19: HTTP 200 [Recibida por DMZ]
  -> Petición #10: HTTP 200 [Recibida por DMZ]
  -> Petición #28: HTTP 200 [Recibida por DMZ]
  -> Petición #13: HTTP 200 [Recibida por DMZ]
  -> Petición #7: HTTP 200 [Recibida por DMZ]
  -> Petición #20: HTTP 200 [Recibida por DMZ]
  -> Petición #5: HTTP 200 [Recibida por DMZ]
  -> Petición #2: HTTP 200 [Recibida por DMZ]
  -> Petición #30: HTTP 200 [Recibida por DMZ]
================================================================
 [RESULTADO] Ráfaga controlada finalizada en 0s.
 [ANÁLISIS FORENSE] En un escenario DoS no controlado:
   1. El consumo de workers y descriptores de archivo satura el servicio.
   2. Mecanismos de defensa: Rate Limiting en Nginx/WAF, CDN y fail2ban.
================================================================
```

Módulo 02: Reconocimiento y Escaneo de Puertos TCP con Netcat

Contexto técnico: Barrido TCP con netcat evaluando puertos 21, 22, 80, 443, 8080 y 3306. Solo el puerto 8080 respondió ABIERTO / OPEN; los restantes resultaron cerrados/filtrados.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 02: Reconocimiento y Escaneo de Puertos en DMZ
================================================================
[INFO] Host objetivo local asignado: servidor-dmz
[SEGURIDAD OK] El host pertenece a la red Docker aislada del laboratorio.
[RECONOCIMIENTO] Analizando puertos estándar en el contenedor objetivo (servidor-dmz)...
  -> Probando puerto 21 (FTP)... [CERRADO / FILTERED]
  -> Probando puerto 22 (SSH)... [CERRADO / FILTERED]
  -> Probando puerto 80 (HTTP)... [CERRADO / FILTERED]
  -> Probando puerto 443 (HTTPS)... [CERRADO / FILTERED]
  -> Probando puerto 8080 (DMZ-WEB)... [ABIERTO / OPEN]
  -> Probando puerto 3306 (MySQL)... [CERRADO / FILTERED]
```

```
================================================================
 [ANÁLISIS FORENSE] Reducción de Superficie de Ataque:
   Solo el puerto 8080 (servicio DMZ) debe estar expuesto.
   Servicios administrativos o bases de datos no deben ser accesibles en la DMZ.
================================================================
```

Módulo 03: Enumeración Controlada de Rutas Web

Contexto técnico: Sondeo de 8 rutas web. Rutas existentes devolvieron 200 y rutas no expuestas devolvieron 404 Not Found sin divulgar trazas de depuración.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 03: Enumeración de Rutas Web (Detección de Directorios)
================================================================
[INFO] Objetivo local asignado: http://servidor-dmz:8080
[SEGURIDAD OK] El objetivo pertenece a la red Docker privada del laboratorio.
[ENUMERACIÓN] Probando rutas conocidas sobre el servidor DMZ...
  -> Ruta probada: /  =>  ENCONTRADO / DISPONIBLE (200)
  -> Ruta probada: /health  =>  ENCONTRADO / DISPONIBLE (200)
  -> Ruta probada: /admin  =>  NO ENCONTRADO (404)
  -> Ruta probada: /config.php  =>  NO ENCONTRADO (404)
  -> Ruta probada: /login  =>  NO ENCONTRADO (404)
  -> Ruta probada: /secret  =>  NO ENCONTRADO (404)
  -> Ruta probada: /backup.zip  =>  NO ENCONTRADO (404)
  -> Ruta probada: /index.html  =>  NO ENCONTRADO (404)
================================================================
 [ANÁLISIS FORENSE] Detección de Reconocimiento Web:
   Una ráfaga de respuestas 404 consecutivas indica escaneo de directorios.
   Defensas: Reglas en WAF (ModSecurity), monitoreo de logs con Fail2ban.
================================================================
```

Módulo 04: Demostración de Exfiltración por DNS (Loopback Local)

Contexto técnico: Demostración técnica de fuga encubierta (MITRE ATT&CK T1048.003).
Diferenciación estricta de valores:

- Valor original simulado: 'clave_ficticia_demo_2026'
- Valor codificado en Base64: 'Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2'
- FQDN consultado: 'Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2.lab.dmz.local'
- Valor recibido y decodificado por el receptor en loopback (127.0.0.1:1053): 'clave_ficticia_demo_2026'

La red con 'internal: true' garantizó que ningún paquete saliera a resolvedores de Internet.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 04: Demostración de Exfiltración por Canal Encubierto DNS
================================================================
[AUDITORÍA DE AISLAMIENTO] Verificando aislamiento de red Docker (internal: true)...
  - La red privada lab-dmz-net no posee enrutamiento hacia Internet.
  - Se previene cualquier reenvío recursivo hacia resolvedores DNS públicos externos.

[CONCEPTO] Técnica de exfiltración de datos vía DNS (T1048.003 - MITRE ATT&CK):
  1. Dato sensible simulado: 'clave_ficticia_demo_2026'
  2. Codificación Base64 sin padding: 'Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2'
  3. Construcción del FQDN malicioso: 'Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2.lab.dmz.local'

[SIMULACIÓN CONTROLADA] Levantando receptor DNS local simulado en loopback...
[DNS QUERY] Enviando consulta A para Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2.lab.dmz.local al receptor
local (127.0.0.1:1053)...
```

```
[DNS-SINKHOLE] Servidor DNS simulado a la escucha en 127.0.0.1:1053...
[CAPTURA FORENSE] Consulta DNS interceptada desde ('127.0.0.1', 57911):
   -> QNAME Recibido: Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2.lab.dmz.local.
   -> Payload Decodificado: Y2xhdmVfZmljdGljaWFfZGVtb18yMDI2

================================================================
 [ANÁLISIS FORENSE] Evidencia de Fuga y Prevención:
   - La consulta viajó estrictamente dentro del contenedor y la red aislada.
   - El payload fue capturado en el QNAME sin tocar la infraestructura pública.
   - Mitigaciones: Inspección de DPI para DNS, bloqueo de túneles y DNSSEC.
================================================================
```

Módulo 05: Simulación de Compromiso en Cadena de Suministro

Contexto técnico: Detección y ejecución controlada del script no autorizado inyectado durante el build de Docker (/app/malicious_dependency.sh), evidenciando la necesidad de análisis estático con Docker Scout y Trivy en CI/CD.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 05: Simulación de Ataque a la Cadena de Suministro (Supply Chain)
================================================================
[INSPECCIÓN] Verificando integridad del artefacto y dependencias del contenedor...

  [ALERTA DE SEGURIDAD - AUDITORÍA DE BUILD]
    Se detectó una dependencia/script no autorizado inyectado durante
    la etapa de construcción (build phase) de la imagen Docker.

--- Inicio de traza simulada ---
[PAYLOAD DEMO] Alerta: Dependencia no autorizada ejecutada en tiempo de ejecución (Runtime).
--- Fin de traza simulada ---

================================================================
 [ANÁLISIS FORENSE] Seguridad en la Cadena de Suministro de Software:
   - Amenaza: Inyección de código malicioso en repositorios de paquetes o Dockerfiles.
   - Mitigaciones:
       1. Firma y verificación de imágenes con Docker Content Trust (Notary / Cosign).
       2. Escaneo de vulnerabilidades en CI/CD (Trivy, Grype, Docker Scout).
       3. Fijación estricta de versiones y hashes en dependencias (Lockfiles).
       4. Principio de menor privilegio y uso de imágenes base mínimas/endurecidas.
================================================================
```

Módulo 06: Simulación de Credential Stuffing / Brute Force

Contexto técnico: Envío de 5 peticiones con identidades ficticias y cabecera Authorization: Basic. Dictamen forense: Todas devolvieron HTTP 200 porque la raíz '/' es pública y no desafía autenticación (no implica autenticación exitosa).

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 06: Simulación Controlada de Credential Stuffing / Brute Force
================================================================
[INFO] Objetivo local asignado: http://servidor-dmz:8080
[SEGURIDAD OK] El objetivo pertenece a la red Docker privada del laboratorio.

[AUDITORÍA TÉCNICA - ANÁLISIS DE RESPUESTAS HTTP]
  - Nota de seguridad: El endpoint raíz '/' del servidor DMZ es un recurso público.
  - No exige desafío 'WWW-Authenticate: Basic realm=...'.
  - Cualquier solicitud HTTP recibe el HTML público con código HTTP 200.

[PRUEBA DE FUERZA BRUTA] Despachando intentos controlados con cabecera Authorization: Basic...
```

```
  -> Petición con usuario [admin_demo]: HTTP 200 [Página pública entregada por DMZ]
  -> Petición con usuario [root_demo]: HTTP 200 [Página pública entregada por DMZ]
  -> Petición con usuario [user_test]: HTTP 200 [Página pública entregada por DMZ]
  -> Petición con usuario [docente_demo]: HTTP 200 [Página pública entregada por DMZ]
  -> Petición con usuario [gestor_test]: HTTP 200 [Página pública entregada por DMZ]

================================================================
 [DICTAMEN FORENSE - DIFERENCIACIÓN TÉCNICA CLAVE]
   □  RECIBIR HTTP 200 != AUTENTICARSE SATISFACTORIAMENTE
   1. Causa técnica del HTTP 200:
      El servidor perimetral no tiene activo un middleware de autenticación
      en la ruta '/'. El servidor ignora cabeceras Authorization no solicitadas
      y devuelve el panel público 200 OK.
   2. En un servicio realmente protegido (ej. /admin o /login):
      - Credenciales incorrectas deben generar: HTTP 401 Unauthorized.
      - Credenciales correctas generan: HTTP 200 OK con token de sesión.
   3. Mitigaciones indispensables para proteger endpoints de autenticación:
       - Desafíos CAPTCHA adaptativos.
       - Rate Limiting estricto en rutas de autenticación.
       - Bloqueo temporal por intentos fallidos (Account Lockout).
       - Autenticación Multifactor (MFA).
================================================================
```

Módulo 07: Proxy Interceptor Man-In-The-Middle (MITM)

Contexto técnico: Microservicio Flask en puerto 8089 interceptando cabeceras y alterando HTML en tránsito con inyección verificada de un banner rojo de alerta.

```
================================================================
 LABORATORIO DE CIBERSEGURIDAD — IU DIGITAL DE ANTIOQUIA
 Estudiante: Mariluz David Martínez
 Módulo 07: Proxy Interceptor y Demostración MITM
================================================================
[INFO] Proxy interceptor iniciado en puerto local (red Docker).
[INFO] Reenvío hacia nodo DMZ: http://servidor-dmz:8080

[MITM INTERCEPTADO] Petición entrante hacia la ruta: /
[CABECERAS INTERCEPTADAS] Método: GET | User-Agent: Mozilla/5.0 (Windows NT 10.0; es-CO)
[MITM ALERTA] Respuesta original obtenida de DMZ (HTTP 200).
[MITM ALERTA] Modificación en tránsito: Inyectado banner HTML visual y comentario de auditoría.
[STATUS COMPROBADO] Código HTTP: 200 OK | Banner inyectado verificado: TRUE

================================================================
 [ANÁLISIS FORENSE] Interceptación Man-In-The-Middle y Tránsito No Cifrado:
   - Amenaza: Un atacante en la misma ruta de red (ARP Spoofing, Proxy no seguro)
     puede inspeccionar y alterar datos en vuelo si no se utiliza TLS de extremo a extremo.
   - Mitigaciones indispensables:
       1. Cifrado TLS/HTTPS estricto (mTLS para servicios internos).
       2. Encabezado HTTP Strict Transport Security (HSTS).
       3. Certificate Pinning y validación rigurosa de cadenas de confianza.
================================================================
```